EXPERIMENT 12

Implementing Security Features and Governance / Administration Practices in Zoho Creator

LOW CODE APPLICATION • LABORATORY REPORT

Experiment aim

To identify and apply security and governance controls for a low-code application that stores personal and membership information.

Application / case context

The Gym Enrollment app captures personal identifiers, contact details, residential address, and fitness/medical notes. The form builder screenshot marks Member Name as personal data and displays a notice that data encryption is not supported for the selected field/configuration. Security controls therefore need to include access restrictions and careful data handling, not just workflow logic.

Report structure: background, design, procedure, verification, results, conclusion and references. Any feature not confirmed by supplied evidence is identified as a proposed design or procedure.

24140172

1. Aim, Objectives and Security Principles

Security in a low-code application includes authentication, authorization, privacy, secure integrations, auditability, data retention, and administrative governance. A secure design assumes that not every user should see or modify every record.

Objectives: classify data; apply least privilege; configure sharing carefully; protect connection secrets; establish data-retention and incident-response procedures; and verify access controls through testing.

Principles: collect only necessary data, use it only for the stated purpose, restrict access, keep accounts accountable, and remove access when no longer needed.

Security controls should be layered. Authentication establishes who is using the app; authorization determines what that user can do; sharing settings determine how the app is exposed; and governance establishes how changes and access are reviewed. A strong password alone does not compensate for a report shared too broadly.

Collect only the data required for the stated business purpose. The gym form contains contact details and a fitness/medical note field, so the team should decide who needs each field and whether it should appear in reports, exports, emails, or screenshots. Avoid copying sensitive information into routine confirmation emails.

Administrative governance includes named accounts, access reviews, change approval, retention rules, and an incident process. If the platform interface reports a security limitation for a field or configuration, document it and assess whether that data should be stored there. Do not assume encryption or access protections exist without checking the current product documentation.

Security review is continuous because data fields, users, integrations, and pages evolve. Add security review to the checklist for each significant change and repeat access tests after changing sharing, permissions, or connection scopes.

The scope of this experiment is deliberately limited to a lab-scale application. It demonstrates the underlying concept and the verification method; it does not establish production readiness without the additional checks described in this report.

Objectives and scope

This experiment studies the controls and administrative practices needed to protect personal data and govern changes over the application lifecycle.

241401072

2. Data Classification and Access

Classify fields into operational data (membership plan and preferred date), personal data (name, email, phone, address), and potentially sensitive fitness or medical notes. Different classes may require different visibility and retention rules.

Limit access to the medical-notes field and any report containing it. Avoid showing sensitive details on a public portal, broad dashboard, or exported report unless the user role needs that information.

Field-level visibility is only one layer. Check form permissions, report permissions, record-level access, portal sharing, exports, and any API integration. Hiding a field in one view does not necessarily prevent access through another route.

Security controls should be layered. Authentication establishes who is using the app; authorization determines what that user can do; sharing settings determine how the app is exposed; and governance establishes how changes and access are reviewed. A strong password alone does not compensate for a report shared too broadly.

Collect only the data required for the stated business purpose. The gym form contains contact details and a fitness/medical note field, so the team should decide who needs each field and whether it should appear in reports, exports, emails, or screenshots. Avoid copying sensitive information into routine confirmation emails.

Administrative governance includes named accounts, access reviews, change approval, retention rules, and an incident process. If the platform interface reports a security limitation for a field or configuration, document it and assess whether that data should be stored there. Do not assume encryption or access protections exist without checking the current product documentation.

Security review is continuous because data fields, users, integrations, and pages evolve. Add security review to the checklist for each significant change and repeat access tests after changing sharing, permissions, or connection scopes.

Access to personal data should be limited not only in the live application but also in exported spreadsheets, screenshots, email notifications, and lab submissions. Replace real personal details with synthetic examples where possible, and do not publish screenshots containing unnecessary contact information.

Administrative changes should be traceable. Record who changed a permission, shared an app, added a connection, or modified a workflow. If the platform offers audit logs for the account, identify where they are accessed and who is allowed to review them.

Review what appears in logs and diagnostic messages. Error details can help a developer troubleshoot, but a log containing a full record payload can expose personal information unnecessarily. Prefer identifiers, timestamps, action names, and redacted error summaries.

Governance should specify how test data is cleaned up, how records are corrected, and who approves external sharing. For the gym app, use synthetic examples in screenshots and avoid including real contact details in reports distributed outside the project team.

Design / configuration summary

Control	Practical check
Authentication	Named users; supported sign-in protections enabled
Authorization	Each role can perform only required actions
Sensitive fields	Health notes restricted to appropriate users
Sharing	No unintended public links or broad portal access
Connections	Minimal OAuth scopes; no hard-coded secrets
Governance	Change log, access review, retention policy
Testing	Attempt unauthorized view/edit/export actions

24140172

3. Security Configuration and Administration

Use individual user accounts and appropriate roles. Enable supported authentication protections, review administrator access, and avoid shared credentials. Remove or disable accounts when a user leaves the project.

Review sharing settings and application access links before publishing. Keep integration connections scoped to the minimum permissions and avoid storing tokens or passwords in plain text fields or scripts.

Use supported platform security features and document any limitations shown in the current interface. The screenshot's message that encryption is not supported for a selected field/configuration should prompt a review of the field's data classification and the platform's current encryption options.

Security controls should be layered. Authentication establishes who is using the app; authorization determines what that user can do; sharing settings determine how the app is exposed; and governance establishes how changes and access are reviewed. A strong password alone does not compensate for a report shared too broadly.

Collect only the data required for the stated business purpose. The gym form contains contact details and a fitness/medical note field, so the team should decide who needs each field and whether it should appear in reports, exports, emails, or screenshots. Avoid copying sensitive information into routine confirmation emails.

Administrative governance includes named accounts, access reviews, change approval, retention rules, and an incident process. If the platform interface reports a security limitation for a field or configuration, document it and assess whether that data should be stored there. Do not assume encryption or access protections exist without checking the current product documentation.

Security review is continuous because data fields, users, integrations, and pages evolve. Add security review to the checklist for each significant change and repeat access tests after changing sharing, permissions, or connection scopes.

Access to personal data should be limited not only in the live application but also in exported spreadsheets, screenshots, email notifications, and lab submissions. Replace real personal details with synthetic examples where possible, and do not publish screenshots containing unnecessary contact information.

Administrative changes should be traceable. Record who changed a permission, shared an app, added a connection, or modified a workflow. If the platform offers audit logs for the account, identify where they are accessed and who is allowed to review them.

Review what appears in logs and diagnostic messages. Error details can help a developer troubleshoot, but a log containing a full record payload can expose personal information unnecessarily. Prefer identifiers, timestamps, action names, and redacted error summaries.

Governance should specify how test data is cleaned up, how records are corrected, and who approves external sharing. For the gym app, use synthetic examples in screenshots and avoid including real contact details in reports distributed outside the project team.

Procedure and configuration checklist

- Classify data and document who needs each field.
- Review users, roles, sharing links, and connection scopes.
- Test unauthorized view, edit, delete, and export attempts.
- Document retention, access review, and incident handling.

24AD1072

4. Governance, Audit and Incident Handling

Governance defines who can create applications, approve changes, share data, add users, and manage integrations. Establish a simple change log: what changed, why, who approved it, and how it was tested.

Define a retention policy for test records and member data. Provide a process to correct inaccurate records and remove data when appropriate under applicable policy and law.

Incident response should include restricting access, identifying affected records, preserving relevant logs, notifying responsible administrators, and documenting corrective actions. Avoid placing personal data in screenshots or public lab reports when not necessary.

Security controls should be layered. Authentication establishes who is using the app; authorization determines what that user can do; sharing settings determine how the app is exposed; and governance establishes how changes and access are reviewed. A strong password alone does not compensate for a report shared too broadly.

Collect only the data required for the stated business purpose. The gym form contains contact details and a fitness/medical note field, so the team should decide who needs each field and whether it should appear in reports, exports, emails, or screenshots. Avoid copying sensitive information into routine confirmation emails.

Administrative governance includes named accounts, access reviews, change approval, retention rules, and an incident process. If the platform interface reports a security limitation for a field or configuration, document it and assess whether that data should be stored there. Do not assume encryption or access protections exist without checking the current product documentation.

Security review is continuous because data fields, users, integrations, and pages evolve. Add security review to the checklist for each significant change and repeat access tests after changing sharing, permissions, or connection scopes.

Access to personal data should be limited not only in the live application but also in exported spreadsheets, screenshots, email notifications, and lab submissions. Replace real personal details with synthetic examples where possible, and do not publish screenshots containing unnecessary contact information.

Administrative changes should be traceable. Record who changed a permission, shared an app, added a connection, or modified a workflow. If the platform offers audit logs for the account, identify where they are accessed and who is allowed to review them.

Review what appears in logs and diagnostic messages. Error details can help a developer troubleshoot, but a log containing a full record payload can expose personal information unnecessarily. Prefer identifiers, timestamps, action names, and redacted error summaries.

Governance should specify how test data is cleaned up, how records are corrected, and who approves external sharing. For the gym app, use synthetic examples in screenshots and avoid including real contact details in reports distributed outside the project team.

Verification checklist

- Review personal-data exposure in all views.
- Test user permissions and connection access.
- Verify that changes are logged and reviewed.

24140172

5. Security Testing and Conclusion

Test with a front-desk user, trainer user, and administrator account. Verify unauthorized users cannot view restricted reports, edit records, export bulk data, or access medical notes. Re-test after changing sharing settings.

Conclusion: security is an ongoing governance process. The Creator application should use least privilege, minimal collection, careful sharing, accountable accounts, and tested retention practices. A trial application should not be treated as production-ready until these controls are reviewed.

Security controls should be layered. Authentication establishes who is using the app; authorization determines what that user can do; sharing settings determine how the app is exposed; and governance establishes how changes and access are reviewed. A strong password alone does not compensate for a report shared too broadly.

Collect only the data required for the stated business purpose. The gym form contains contact details and a fitness/medical note field, so the team should decide who needs each field and whether it should appear in reports, exports, emails, or screenshots. Avoid copying sensitive information into routine confirmation emails.

Administrative governance includes named accounts, access reviews, change approval, retention rules, and an incident process. If the platform interface reports a security limitation for a field or configuration, document it and assess whether that data should be stored there. Do not assume encryption or access protections exist without checking the current product documentation.

Security review is continuous because data fields, users, integrations, and pages evolve. Add security review to the checklist for each significant change and repeat access tests after changing sharing, permissions, or connection scopes.

A good conclusion separates observed results from expected results. Report any failed test and the next corrective action plainly; a documented limitation is more useful than claiming a pass that the evidence does not support.

Learning outcomes

- Classified data by sensitivity.
- Identified authorization, sharing and governance controls.
- Designed a security test and review process.

Conclusion

Conclusion: security is an ongoing governance process. The Creator application should use least privilege, minimal collection, careful sharing, accountable accounts, and tested retention practices. A trial application should not be treated as production-ready until these controls are reviewed.

References

Zoho Creator security: https://www.zoho.com/creator/security.html

Zoho privacy policy: https://www.zoho.com/privacy.html

Zoho Creator Help: https://www.zoho.com/creator/help/

24140172

6. Privacy-by-Design and Security Review

Privacy-by-design begins before a form is published. Ask whether each field is necessary, who needs it, how long it should be retained, and whether it should appear in reports, exports, email templates, or screenshots.

Email notifications should contain only the information needed for confirmation. Avoid including medical notes or full residential addresses in routine messages. Test email recipients and prevent unintended disclosure through copied recipients or shared inboxes.

Governance should include ownership, change approval, access review, and incident response. Document the platform's current security controls and limitations; do not assume a feature exists because it is common in other systems.

Access to personal data should be limited not only in the live application but also in exported spreadsheets, screenshots, email notifications, and lab submissions. Replace real personal details with synthetic examples where possible, and do not publish screenshots containing unnecessary contact information.

Administrative changes should be traceable. Record who changed a permission, shared an app, added a connection, or modified a workflow. If the platform offers audit logs for the account, identify where they are accessed and who is allowed to review them.

Practical application to the lab

The Gym Enrollment app captures personal identifiers, contact details, residential address, and fitness/medical notes. The form builder screenshot marks Member Name as personal data and displays a notice that data encryption is not supported for the selected field/configuration. Security controls therefore need to include access restrictions and careful data handling, not just workflow logic.

Evaluation criteria

A satisfactory lab result should be reproducible, supported by a clear configuration or test record, and honest about limitations. Record the setup, test input, expected result, actual result, and evidence. If a feature was not enabled or tested in the current account, report that as a limitation and describe the procedure needed to complete it.

Checklist for submission

- Confirm the report matches the experiment title and stated objectives.
- Keep screenshots and configuration details aligned with what was actually performed.
- Separate verified outcomes from proposed implementation steps.
- Recheck the final PDF page layout before submission.

24149172

7. Governance Checklist and Final Recommendations

Maintain an inventory of applications, owners, data categories, integrations, users, and external shares. Record who approves changes and how quickly access is removed when roles change.

Review security settings after new fields, reports, pages, or integrations are added. A new dashboard may unintentionally expose a field that was not visible in the original form.

Final recommendation: treat security as a lifecycle activity—design, configure, test, monitor, review, and improve.

Access to personal data should be limited not only in the live application but also in exported spreadsheets, screenshots, email notifications, and lab submissions. Replace real personal details with synthetic examples where possible, and do not publish screenshots containing unnecessary contact information.

Administrative changes should be traceable. Record who changed a permission, shared an app, added a connection, or modified a workflow. If the platform offers audit logs for the account, identify where they are accessed and who is allowed to review them.

Practical application to the lab

The Gym Enrollment app captures personal identifiers, contact details, residential address, and fitness/medical notes. The form builder screenshot marks Member Name as personal data and displays a notice that data encryption is not supported for the selected field/configuration. Security controls therefore need to include access restrictions and careful data handling, not just workflow logic.

Evaluation criteria

A satisfactory lab result should be reproducible, supported by a clear configuration or test record, and honest about limitations. Record the setup, test input, expected result, actual result, and evidence. If a feature was not enabled or tested in the current account, report that as a limitation and describe the procedure needed to complete it.

Checklist for submission

- Confirm the report matches the experiment title and stated objectives.
- Keep screenshots and configuration details aligned with what was actually performed.
- Separate verified outcomes from proposed implementation steps.
- Recheck the final PDF page layout before submission.

2414010072